PROJECT REVIEW -1

ADVANCED PYTHON PROGRAMMING

Name: Rishi Kethan Reddy **Register No.:** 23MID0139

1. Title

PyPI Sentinel: Pre-Install Malware and Typosquat Detection for Python Packages

2. What does the website do?

Sentinel checks a Python package for malware and copycat names before you install it.
It shows a 0-100 risk score with the exact findings and file locations behind it.

3. Frontend

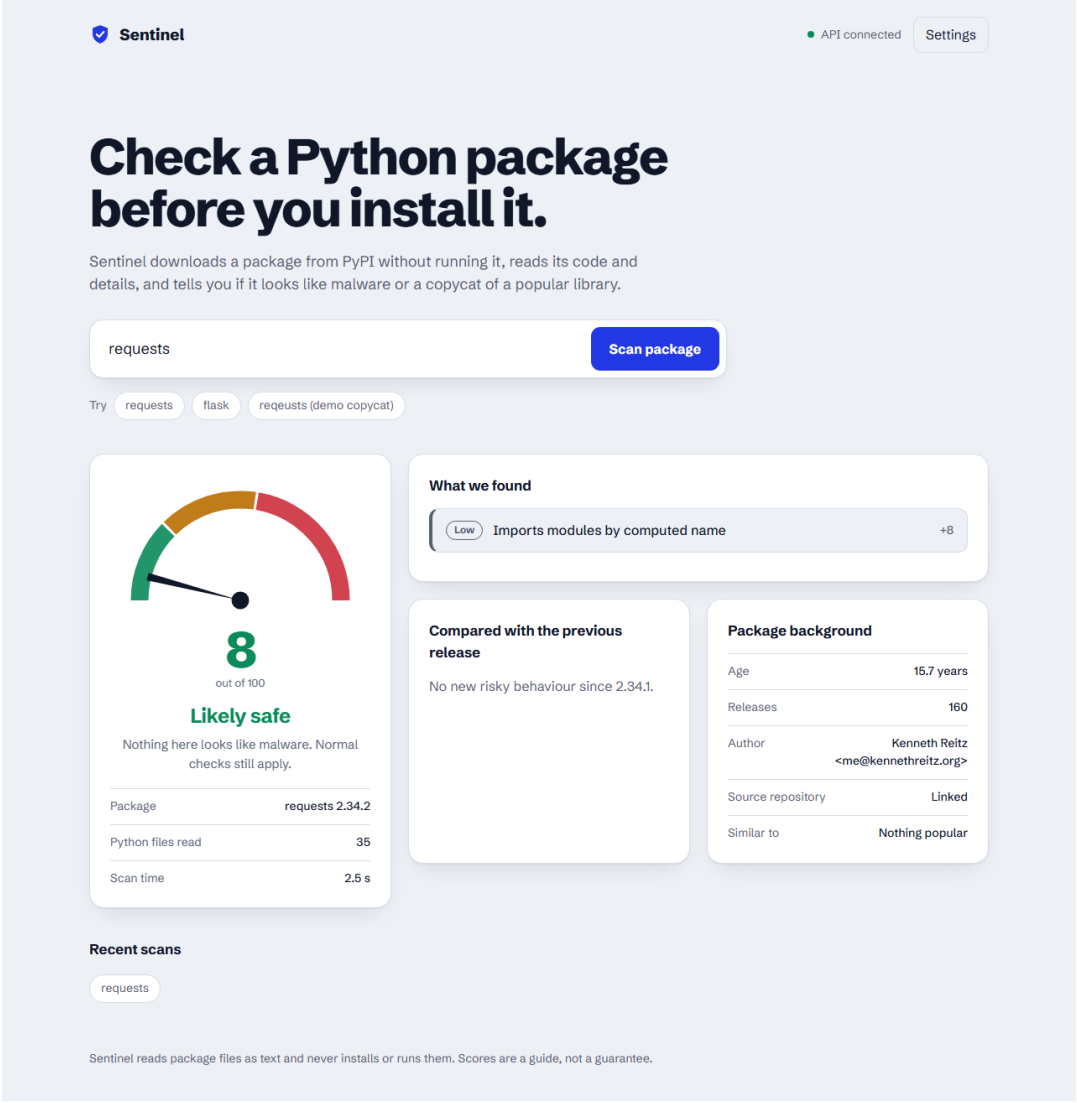


Figure 1: Home page with the package search box, scan results with the risk gauge and findings

4. Backend architecture

The backend is a Python FastAPI service. A scan never installs or runs the package.

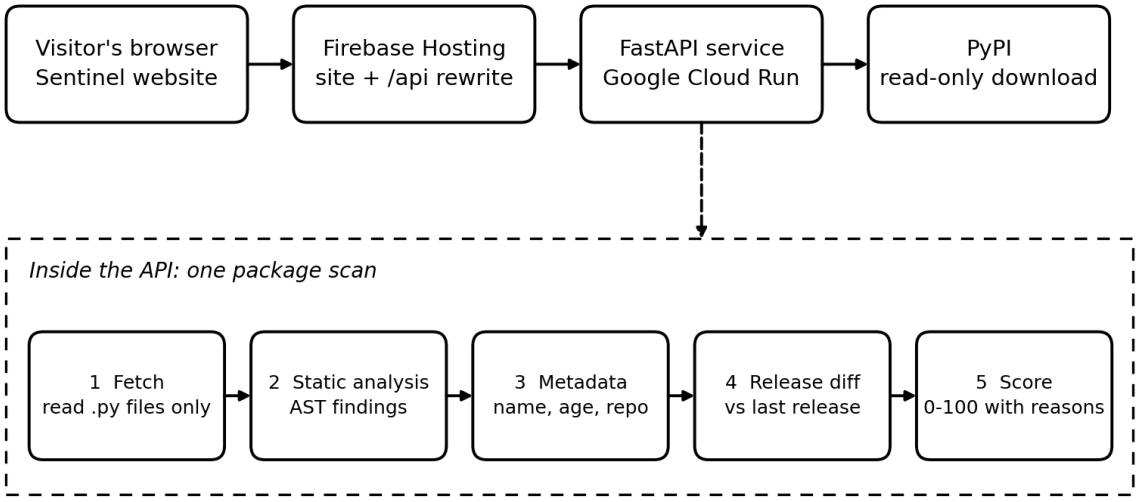


Figure 2: Backend architecture

- **Fetcher:** downloads the package archive from PyPI and reads only the .py files in memory.
- **Static analysis:** parses the code with Python's ast module and finds hidden payloads, dynamic exec or eval, network calls, system commands and credential-file paths, tagged by when the code runs (install, import or runtime).
- **Metadata:** measures how close the name is to popular packages (typosquatting), the package age and whether a source repository is linked.
- **Release diff:** compares the version with the previous release and reports newly added risky behaviour.
- **Scoring:** combines the findings with weighted rules into a 0-100 score and returns JSON with the reasons. A machine-learning classifier is planned as the next stage.
- **Clients:** the same engine powers a command-line tool, and the partner website DepCheck calls this API.

5. Are you hosting?

Yes. The website and its API will be hosted on Firebase and Google Cloud.

Website (frontend)	Firebase Hosting
API (backend)	Google Cloud Run (FastAPI in a container), reached through a Firebase Hosting rewrite from /api/**